SYSTEM DESIGN

API Gateways Visual Guide

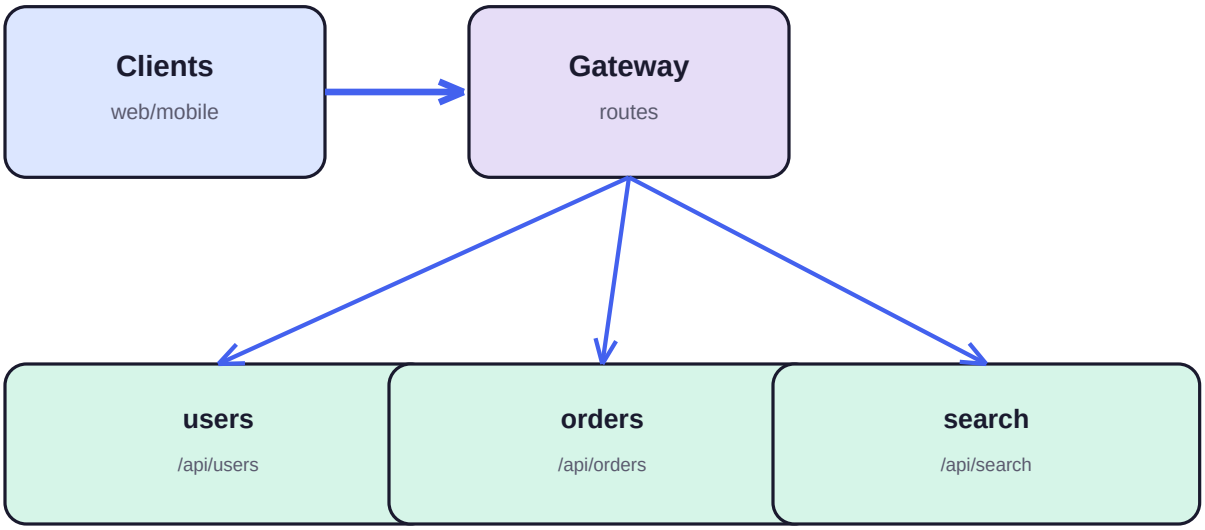
One front door for your APIs:
routing, auth, limits, and aggregation.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

The Single Entry Point

Clients talk to the gateway; the gateway knows the service map.

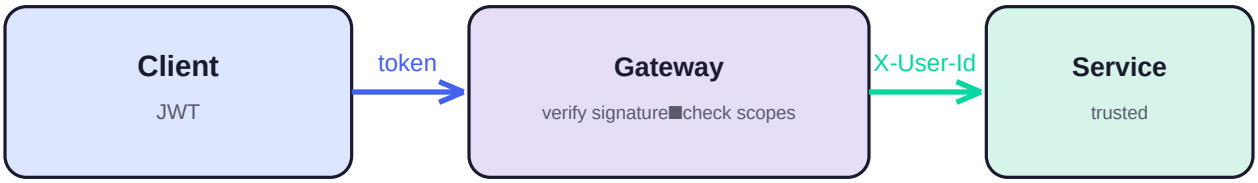


Path-based (/api/orders/*), host-based (orders.api.com), or header-based routing -- one public surface, many backends.

STEP 2/6

Auth Termination at the Edge

Validate identity once; backends trust the gateway's verdict.

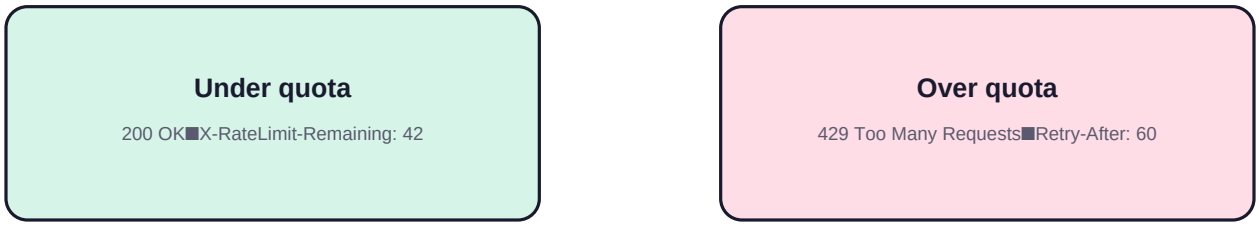


- Terminate TLS here, validate JWTs (JWKS), enforce OAuth2 scopes -- once, centrally.
- Forward identity as headers (X-User-Id, X-Roles); services stay dumb about auth.
- Central policy = one place to rotate keys, revoke tokens, and audit access.

STEP 3/6

Rate Limiting Protects Backends

The gateway is the bouncer: quotas per key, per route, per user.

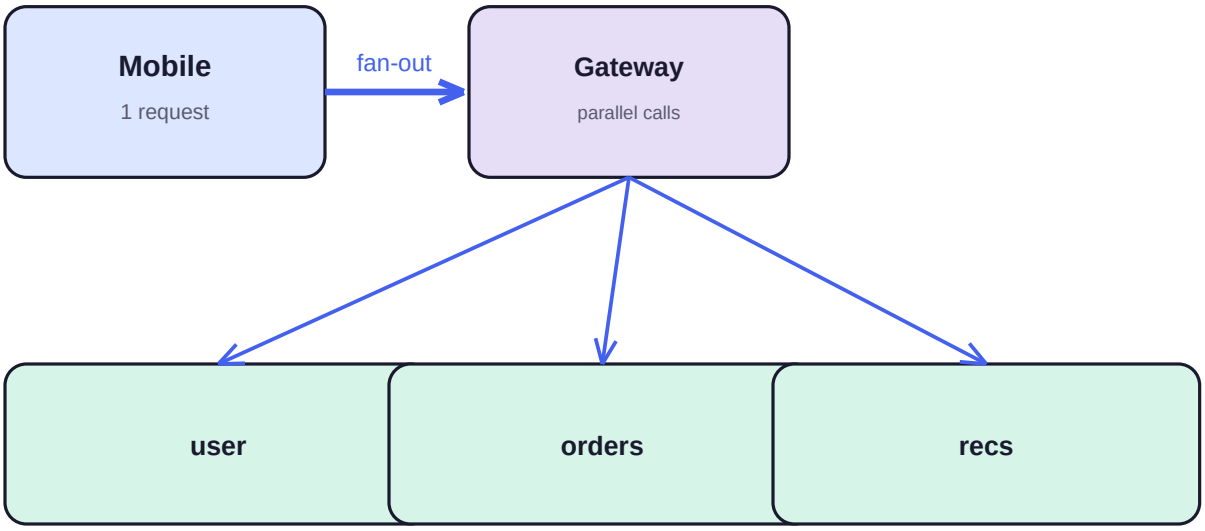


- Tiers: free 100/min, pro 10k/min -- limits are a product feature and a cost control.
- Distributed counting (Redis) so every gateway replica enforces the same budget.
- Always return headers + Retry-After: a limit clients cannot see is a limit they will fight.

STEP 4/6

Request Aggregation

One client call becomes many backend calls -- merged at the edge.

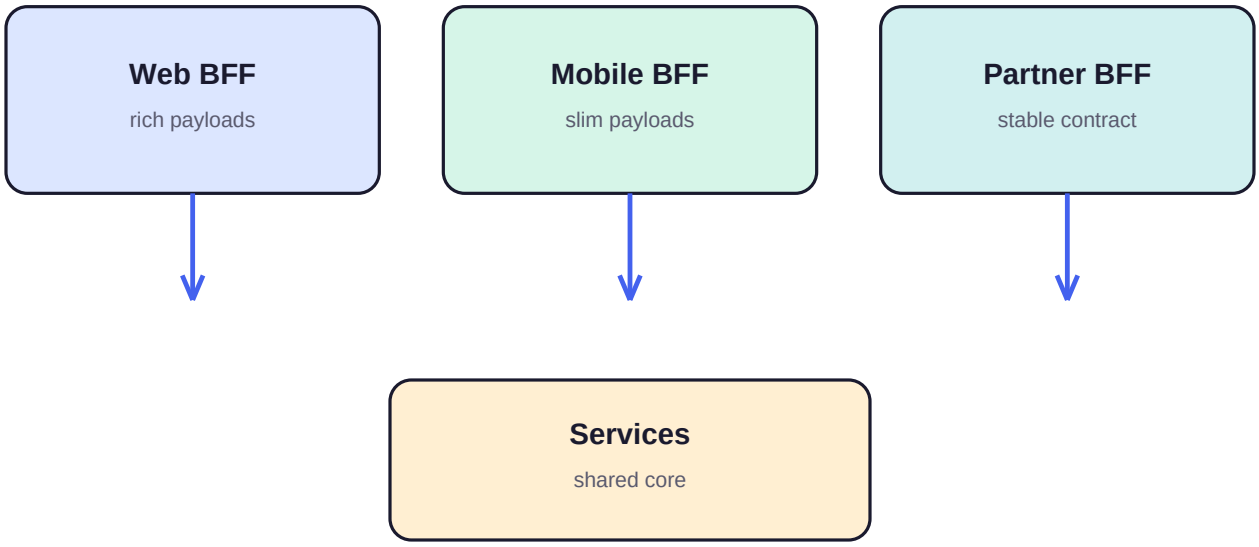


Cuts mobile round-trips (latency, battery) but the gateway now owns partial-failure semantics: fail whole or degrade?

STEP 5/6

BFF: Backend for Frontend

One tailored gateway per client type -- not one gateway to rule them all.



- Each BFF shapes data for its client's needs; teams evolve UI contracts independently.
- Cost: more services to run. Start with one gateway; split into BFFs when client needs truly diverge.

STEP 6/6

Cross-Cutting Superpowers

Everything every service needs, done once.

Observability

one place for access logs, tracing spans, metrics

Caching

cache GETs at the edge -- kill duplicate backend hits

Transformation

version translation: v1 clients, v2 services

Resilience

timeouts, retries, circuit breakers per route

Warning: the gateway is a single point of failure -- run it multi-AZ, keep its logic stateless.

STEP ✓/✓

Key Takeaways

API Gateways — Remember

- The gateway is the single public entry: routing, TLS, and a stable contract over many services.
- Terminate auth at the edge -- validate tokens once, forward identity as headers.
- Rate limit per key/route/user; communicate quotas with headers and 429 + Retry-After.
- Aggregate backend calls for chatty clients; split into BFFs when client needs diverge.
- Centralize logging, tracing, caching, and resilience -- but keep the gateway stateless and redundant.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev